Proxmox VE Security

Day 2: Network, Storage & Operational Security

Day 2 — Agenda

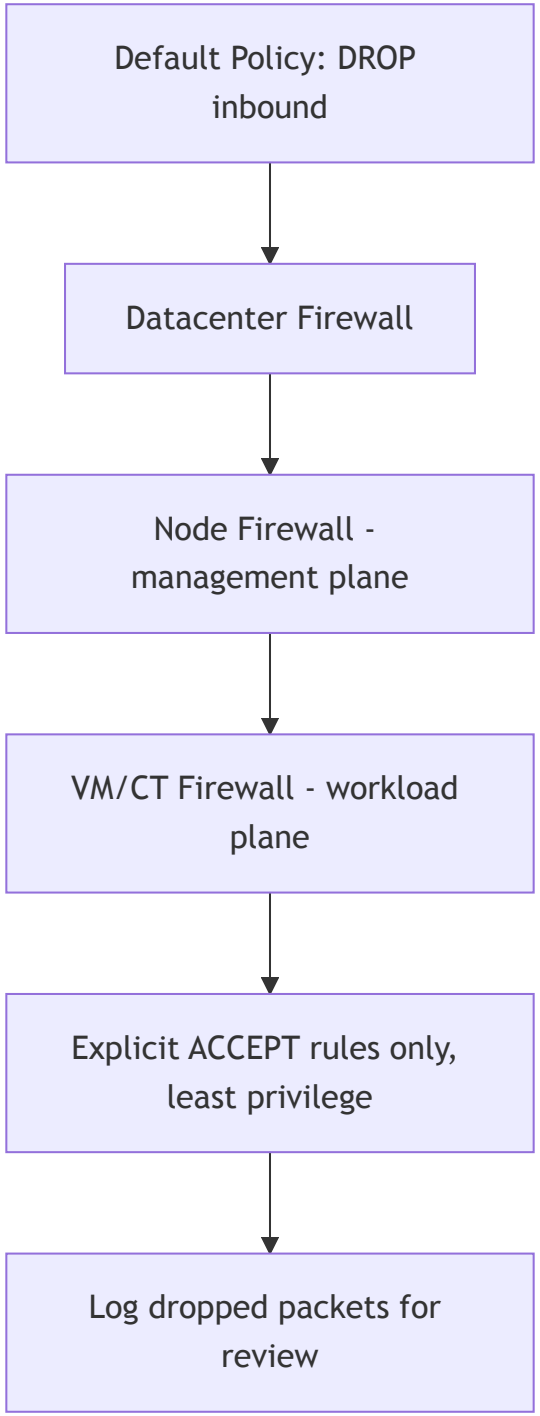
1. Recap: Day 1 Key Points
2. Firewall Architecture — Datacenter, Node & VM Rules
3. Network Segmentation & VLAN Isolation Strategies
4. Securing Storage — Encryption at Rest (ZFS, Ceph)
5. Proxmox Backup Server Security & Encrypted Backups
6. Logging, Monitoring & SIEM Integration

7. Vulnerability Management & Patch Strategy
8. Incident Response for Virtualized Environments
9. Compliance Considerations (ISO 27001, CIS Benchmarks)
10. Capstone Lab: Securing a Proxmox Cluster End-to-End

1. Recap: Day 1 Key Points

- Layered security: network, host, hypervisor, guest, data
- 2FA + realm-based auth should protect **every** administrative account
- RBAC works best with narrow, custom least-privilege roles
- API tokens need privilege separation and their own scoped ACLs
- TLS + audit logging are baseline requirements

Today: network, storage, logging, and the operational disciplines (patching, incident response, compliance) that keep a hardened deployment hardened over time.

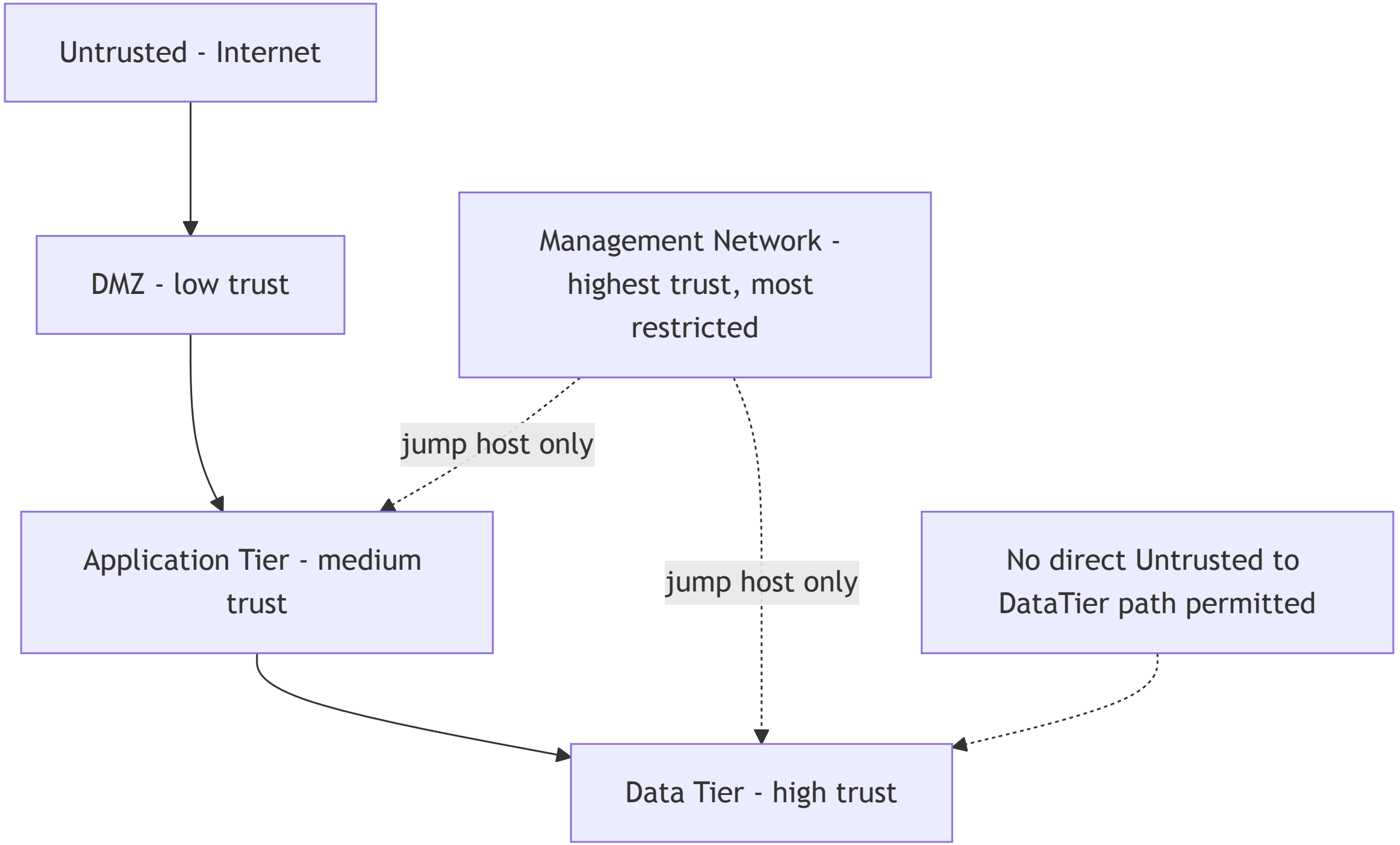

Default Policy: DROP inbound
Datacenter Firewall
Node Firewall - management plane
VM/CT Firewall - workload plane
Explicit ACCEPT rules only, least privilege
Log dropped packets for review

2. Firewall Architecture

```
# Default-deny at the datacenter level
pvesh set /cluster/firewall/options --enable 1 --policy_in DROP --policy_out ACCEPT

# VM-level rule: only allow HTTPS from the load balancer subnet
pvesh create /nodes/pve1/qemu/100/firewall/rules \
  --action ACCEPT --type in --dport 443 --proto tcp --source 10.20.5.0/24
```

Review firewall rule sets periodically — an "ACCEPT ANY ANY" rule left over from initial testing is one of the most common real-world findings in a security review.

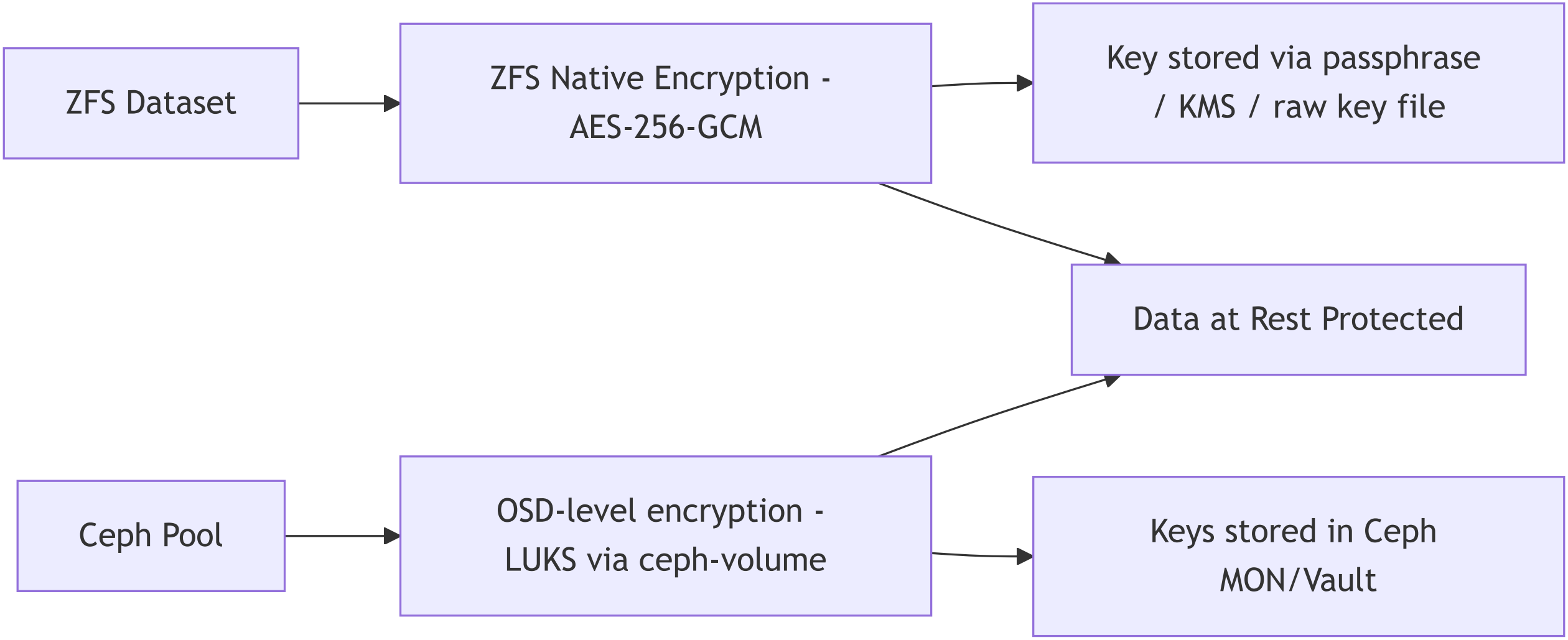

Untrusted - Internet
DMZ - low trust
Management Network - highest trust, most restricted
jump host only
Application Tier - medium trust
jump host only
No direct Untrusted to DataTier path permitted
Data Tier - high trust

3. Network Segmentation & VLAN Isolation Strategies

```
# VLAN-tag a VM's network device into an isolated segment
qm set 100 --net0 virtio,bridge=vmbr0,tag=30

# SDN VNet approach: dedicated zone for management traffic
pvesh create /cluster/sdn/vnets --vnet mgmtnet --zone mgmt-zone
```

The **management network itself** (where the web UI/API and corosync live) deserves the strictest isolation of all — a compromise there can cascade into control over the entire cluster.


ZFS Dataset
ZFS Native Encryption - AES-256-GCM
Key stored via passphrase / KMS / raw key file
Data at Rest Protected
Ceph Pool
OSD-level encryption - LUKS via ceph-volume
Keys stored in Ceph MON/Vault

4. Securing Storage — Encryption at Rest

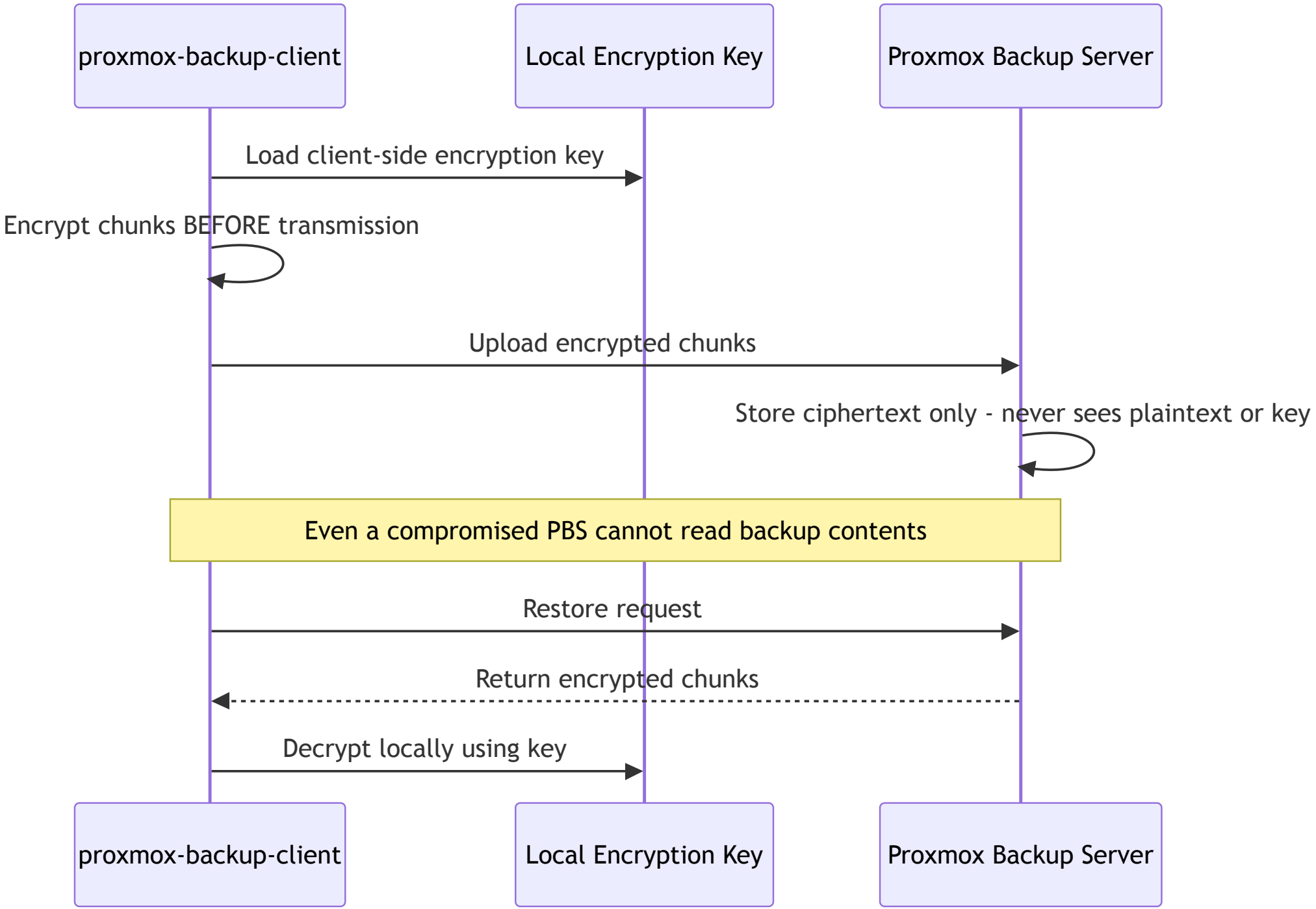
```
# ZFS native encryption on a new dataset
zfs create -o encryption=aes-256-gcm -o keyformat=passphrase tank/encrypted-vms

# Ceph: enable OSD encryption at creation time
pveceph osd create /dev/sdb --encrypted 1
```

Encryption at rest protects against **physical disk theft/disposal risk** — it does NOT protect against a compromised, already-authenticated host (the host holds the keys needed to read the data live).

5. Proxmox Backup Server Security & Encrypted Backups

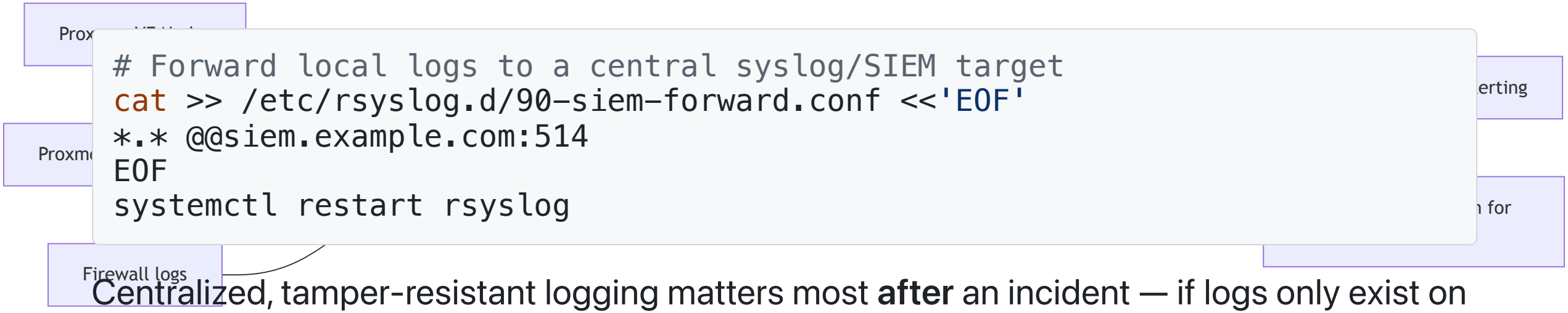
PBS supports **client-side encryption** — chunks are encrypted before they ever leave the source node, so even a fully compromised PBS server cannot read backup contents.


proxmox-backup-client
Local Encryption Key
Proxmox Backup Server
Load client-side encryption key
Encrypt chunks BEFORE transmission
Upload encrypted chunks
Store ciphertext only - never sees plaintext or key
Even a compromised PBS cannot read backup contents
Restore request
Return encrypted chunks
Decrypt locally using key
proxmox-backup-client
Local Encryption Key
Proxmox Backup Server

```
# Generate and register a client encryption key
proxmox-backup-client key create /etc/pve/priv/storage/pbs-main.enc
proxmox-backup-client key paperkey /etc/pve/priv/storage/pbs-main.enc
```

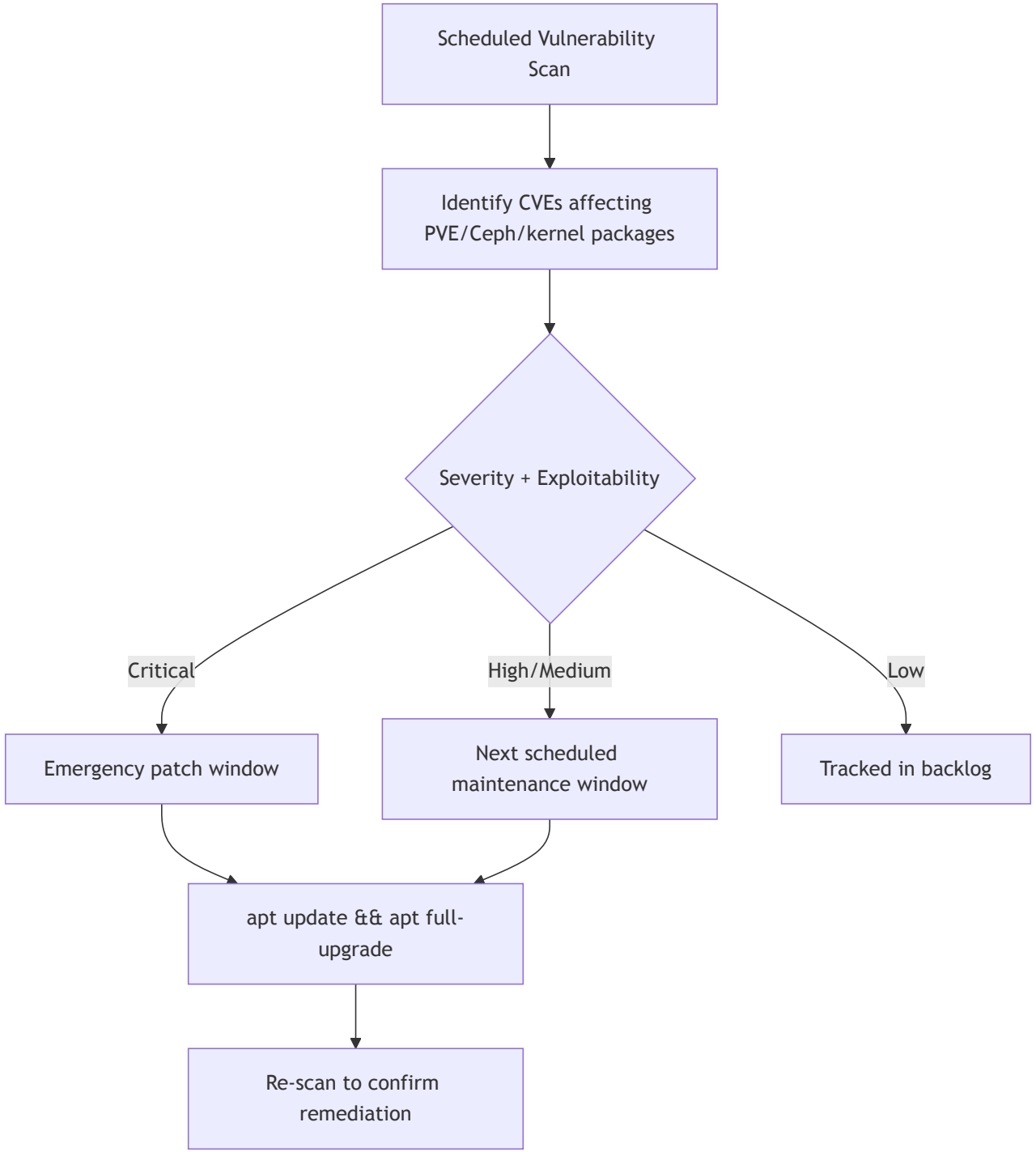
Print and store the paper key recovery sheet somewhere physically secure and offline — losing the encryption key with no backup means losing access to every encrypted backup, permanently.

6. Logging, Monitoring & SIEM Integration




```
# Forward local logs to a central syslog/SIEM target
cat >> /etc/rsyslog.d/90-siem-forward.conf <<'EOF'
*.* @@siem.example.com:514
EOF
systemctl restart rsyslog
```

Centralized, tamper-resistant logging matters most **after** an incident — if logs only exist on the compromised host itself, an attacker with root can simply delete them.


Scheduled Vulnerability Scan
Identify CVEs affecting PVE/Ceph/kernel packages
Severity + Exploitability
Critical
High/Medium
Low
Emergency patch window
Next scheduled maintenance window
Tracked in backlog
apt update && apt full-upgrade
Re-scan to confirm remediation

7. Vulnerability Management & Patch Strategy

```
# Check for available security-relevant updates
apt list --upgradable
pveversion -v

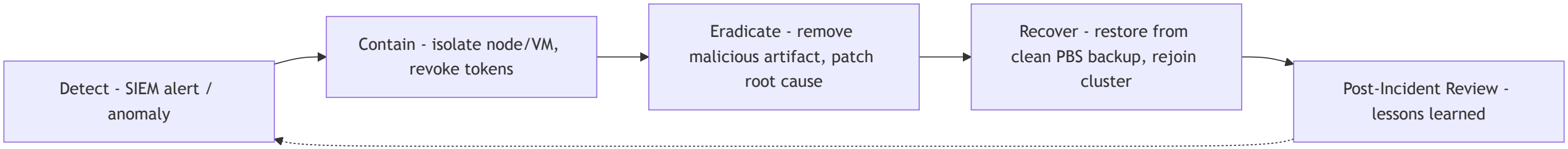
# Track CVEs affecting your stack via Debian Security Tracker / PVE forum
```

Define an explicit **patch SLA** (e.g. critical CVEs within 48 hours, others within the next maintenance window) — "we'll patch it eventually" is not a policy an auditor will accept.

8. Incident Response for Virtualized Environments

Virtualization-specific IR considerations:

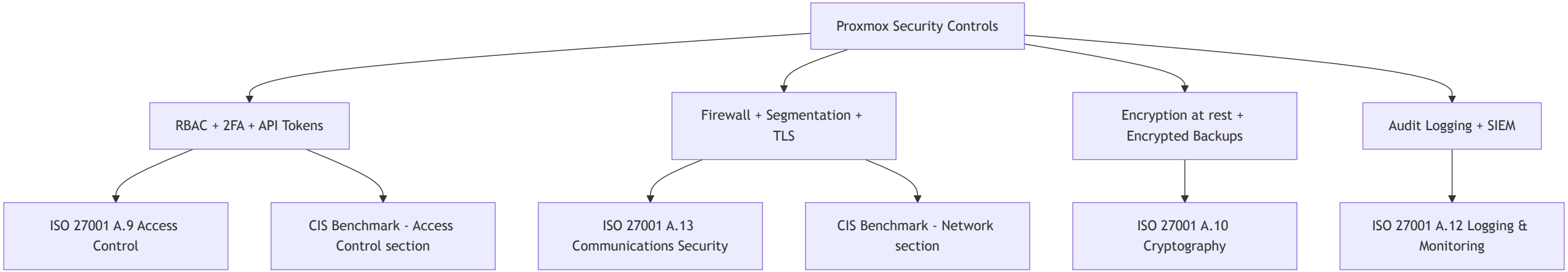
- **Snapshot the affected VM before remediation** — preserves forensic evidence
- **Isolate via firewall/network**, not just shutdown — shutting down can destroy volatile evidence (memory state) needed for analysis
- **Revoke API tokens and rotate credentials** touched by the incident immediately
- **Restore from a known-clean PBS backup**, not from the compromised disk


Detect - SIEM alert / anomaly
Contain - isolate node/VM, revoke tokens
Eradicate - remove malicious artifact, patch root cause
Recover - restore from clean PBS backup, rejoin cluster
Post-Incident Review - lessons learned

9. Compliance Considerations

Control area	ISO 27001	CIS Benchmarks
Access control (RBAC, 2FA)	A.9	Access Control section
Network security (firewall, segmentation)	A.13	Network section
Cryptography (encryption at rest, TLS)	A.10	Cryptography section
Logging & monitoring	A.12	Logging section

Map your actual Proxmox VE configuration to these control families **before** an audit — retrofitting compliance evidence under time pressure is far harder than documenting it as you build.


Proxmox Security Controls
RBAC + 2FA + API Tokens
Firewall + Segmentation + TLS
Encryption at rest + Encrypted Backups
Audit Logging + SIEM
ISO 27001 A.9 Access Control
CIS Benchmark - Access Control section
ISO 27001 A.13 Communications Security
CIS Benchmark - Network section
ISO 27001 A.10 Cryptography
ISO 27001 A.12 Logging & Monitoring

10. Capstone Lab: Securing a Proxmox Cluster End-to-End

Working through a full scenario, apply everything from both days:

1. Lock down firewall rules to least-privilege, default-deny
2. Segment management/app/data traffic with VLANs or SDN zones
3. Enable ZFS encryption on a new dataset
4. Configure a client-encrypted PBS backup job
5. Forward logs to a central target and simulate an incident response walkthrough
6. Map your final configuration to at least 3 ISO 27001 control families

Day 2 — Key Takeaways

- Firewall + network segmentation should follow **default-deny**, reviewed periodically for stale rules
- Encryption at rest and client-side encrypted backups protect against different threats — use both
- Centralized logging survives a host compromise; local-only logging does not
- Patch SLAs and rehearsed incident response turn security from a one-time project into an ongoing practice
- Compliance mapping is easiest when done **continuously**, not retrofitted for an audit